My health @ EU
eHealth Digital Service Infrastructure
A service provided by the European Union

My Health @ EU
eHealth Digital Service Infrastructure
Electronic cross-border health services **in the EU**

SAML Profile

DOCUMENT VERSION 10.0.0

DATE 01/06/2026

STATUS Wave 10 Operation Ready

DG SANTE, MyHealth@EU, 2026
Reuse is authorised, provided the source is acknowledged.

COVER AND CONTROL PAGE OF DOCUMENT	
Document name:	SAML Profile
Distribution level*:	PU
Status:	Wave 10 Operation Ready
Author(s): Organization:	eHealth DSI provider

* Distribution level: PU = Public, PP = Restricted to other programme participants, RE = Restricted to a group specified by the consortium, CO = Confidential, only for members of the consortium.

ABSTRACT
This normative binding specifies the mapping of the eHealth DSI HP identity and treatment context claims onto the SAML 2.0.

CHANGE HISTORY				
Version	Date	Status Changes	From	Review
V10.0.0	01/06/2026	Wave 10 Operation Ready: CP-090 EUDI Wallet integration	eHealth DSI Solution Provider	
V10.0.0-RC	04/05/2026	Wave 10 Release Candidate: CP-090 EUDI Wallet integration	eHealth DSI Solution Provider	
V9.0.0	07/07/2025	Wave 9 Operation Ready Update permissions for new services	eHealth DSI Solution Provider	Adjusted after final review
V9.0.0	04/06/2025	Wave 9 Operation Ready Update permissions for new services	eHealth DSI Solution Provider	
V8.1.0	28/03/2025	Wave 8 Release Candidate Small bugfixes and improvements	eHealth DSI Solution Provider	
V8.1.0-RC	28/02/2025	Wave 8 Release Candidate Small bugfixes and improvements	eHealth DSI Solution Provider	
V8.0.1	24/02/2025	Wave 8 Operation Ready Small bugfixes and improvements	eHealth DSI Solution Provider	

V8.0.1	06/01/2025	Wave 8 Release Candidate Small bugfixes and improvements	eHealth DSI Solution Provider	
V8.0.0	31/05/2024	Wave 8 Operation Ready Implement modifications for the DICOM Audit standard	eHealth DSI Solution Provider	
V8.0.0-RC	26/04/2024	Wave 8 Release Candidate Implement modifications for the DICOM Audit standard	eHealth DSI Solution Provider	
V7.0.0	18/07/2023	Wave 7 Operation Ready Administrative update	eHealth DSI Solution Provider	
V7.0.0	05/06/2023	Administrative update (Version-bump). No content updates.	eHealth DSI Solution Provider	
V6.3.0	05/06/2023	Wave 6 Operation Ready - corresponding to OpenNCP 6.3.0 SR (Stable Release) – IHE Technical Framework Revision 19 (CP-064 SAML token) Processing Member States feedback.	eHealth DSI Solution Provider	
V6.3.0-RC	31/05/2023	Wave 6: CP-064 XUA SAML (Purpose of Use, Role and namespaces consolidation)	eHealth DSI Solution Provider	
V6.2.0	11/01/2023	Wave 6 Release Candidate: CP-064 XUA SAML Update. Changes in Identity Assertions, Purpose of Use and Treatment Relationship Confirmation	eHealth DSI Solution Provider	
V6.1.0	29/07/2022	Wave 6 Operation Ready	eHealth DSI Solution Provider	
V6.0.0	29/04/2022	Wave 6 Release Candidate: administrative update, updating URLs from CEF Digital to FPFIS	eHealth DSI Solution Provider	
V5.0.1	07/06/2021	Wave 5 Release Candidate:	eHealth DSI Solution Provider	

		Consolidation and clarification of the Nest of Kin assertion		
V5.0.0	30/04/2021	Wave 5 Release Candidate – CP-039 and CP-046 integration – Submitted for eHMSEG adoption	eHealth DSI Solution Provider	
V4.0.0	15/05/2020	Wave 4 Operation Ready – SAML elements integration to support CP-036 and CP-042	eHealth DSI Solution Provider	
V3.1.0	04/09/2019	Wave 3 HotFix Integrate the modifications linked to the CP-023_SAML_Structural_Role	eHealth DSI Solution Provider	
V3.0.0	02/07/2019	Administrative update (Version-bump). No content updates.	eHealth DSI Solution Provider	
V2.2.0	30/04/2018	Wave 2 Operation Ready - Implementation of CP-014	eHealth DSI Solution Provider	
V2.1.0	01/06/2017	Wave 1 Operation Ready - Released for eHMSEG adoption	eHealth DSI Solution Provider	
V2.0.1	21/04/2017	Integrate the modifications linked to the CP-002	eHealth DSI provider	
V2.0.0	28/03/2017	Remove all references to epSOS and requirements	eHealth DSI provider	
V 1.1	17/12/2013	Publish	Fraunhofer FOKUS	

TABLE OF CONTENTS

TABLE OF CONTENTS **4**

1 Introduction **5**
1.1 eHealth DSI Identity and Context Claims *5*
1.2 The OASIS SAML v2.0 Standard *5*
1.2.1 SAML Assertions 6
1.2.2 Issuance and Brokerage of SAML Assertions 6
1.2.3 Relationship to IHE XUA Integration Profile 6
1.3 Related Documents *6*
1.4 Conventions *7*
1.4.1 Data Element Optionality 7
1.4.2 Namespaces 7
1.5 Terms and Definitions *7*
1.6 Status of this Binding *8*

2 eHealth DSI Professional Identity Assertion **8**
2.1 Generic Structure of the Identity Assertion *8*
Assertion consumers MUST reject any HCP Identity Assertion that contains a SubjectConfirmationData element, so that the prohibition is enforceable and not just a table annotation *9*
2.2 Assertion Signature *10*
2.3 HP Identity Attributes *10*
2.4 Audit Trail Consideration *12*
2.5 Permission Codes *12*

3 Next of Kin Identity Assertion **13**
3.1 Generic Structure of the Next of Kin Assertion *13*
3.2 Assertion Signature *14*
3.3 Next of Kin Attributes *14*
3.4 Audit Trail Consideration *16*

4 Treatment Relationship Confirmation Assertion **17**
4.1 Generic Structure of the Treatment Relationship Assertion *17*
4.2 Assertion Signature *18*
4.3 Patient Identity and Treatment Context Attributes *18*
4.4 EUDI Wallet PID Sourcing Attributes (CP090) *18*
4.5 Audit Trail Consideration *19*

5 References **20**
5.1 Normative References *20*
5.2 Non-Normative References (IHE XUA Profile) *20*

6 eHealth DSI Common Component Specification (non-normative) **20**
6.1 NCP-B STS specification *22*
6.1.1 SAML HTTP-POST Web Browser SSO 22
6.1.2 NCP-B STS Specification: WS-Trust 22
6.1.3 NCP-A's STS: Validate an IdA 23
6.2 TRC-STS: Issue a new TRC Assertion *23*

1 Introduction

This normative binding specifies the mapping of the eHealth DSI Healthcare Provider identity, the next of kin identity and treatment context claims onto the SAML 2.0.

1.1 eHealth DSI Identity and Context Claims

Before releasing medical data to a foreign country, the data controller who is responsible for that data MUST make sure that the respective data transaction complies with the regulations of eHealth DSI (e.g. does not interfere with patient privacy).
For performing this verification, the data controller must be aware of

- The identity and authenticity of the data requestor.

And:

- The identity and authenticity of the guardian of the patient (optional).

And:

- The kind of (treatment) relationship between the data requestor and the patient.

[Interoperability Specification] requests that the respective information is encoded as identity and context claims which can be piggybacked with any eHealth DSI transaction.
Following the IHE access control domain model and terminology [IHE WPAC] these claims are encapsulated within two different assertions:

- The HP Identity Assertion (IdA) is issued from within the Subject Domain and contains claims about the identity, authenticity, affiliation and roles of the health professional who is requesting medical data from a foreign country.
- The Treatment Relationship Confirmation (TRC) assertion is issued from within the context domain and contains claims about the relationship of the data requestor and the patient as well as claims about the treatment context (e.g. emergency access).
- The Next of Kin (NoK) assertion is issued from within the context domains and contains claims about the identity of the guardian and the patient.

Any NCP injecting a SAML assertion to an eHealth DSI request MUST vouch for the accuracy, integrity and authenticity of all claims encapsulated within that assertion. The assertion MUST be digitally signed by the vouching NCP.

In order to enable other MS (Member State) to access a MS's eHealth DSI services the service endpoints and digital certificates must be registered in a way that allows each MS to discover all other MS's service endpoints and verify the services' authenticity. For providing such a register, eHealth DSI makes use of "Service Metadata Publisher files" where each MS provides information about its managed services in a central service registry.

1.2 The OASIS SAML v2.0 Standard

The OASIS Security Assertion Markup Language [OASIS SAML 2.0] is an XML framework for sharing identity, authenticity and authorization claims within a distributed environment.
The standard defines:

- Assertions for encoding identity, authenticity, and authorization claims
- Protocols for interacting with services which manage the lifecycle of SAML assertions
- Bindings for implementing the protocols on different platforms.
- Profiles for adapting assertions and protocols to specific scenarios.

The eHealth DSI HP Identity Assertion, the eHealth DSI Next of Kin Assertion and the eHealth DSI TRC Assertion are all profiles on the SAML assertion specification.

1.2.1 SAML Assertions

SAML Assertions encapsulate statements about a subject. Such statements may cover the context of subject authentication, describing attributes about the subject and/or the subject's permissions. Each SAML assertion additionally contains information about the issuer of the assertion and the lifecycle of the assertion (e.g. validity conditions). SAML assertions are usually digitally signed by their issuer.

1.2.2 Issuance and Brokerage of SAML Assertions

SAML assertions are issued by a so-called Identity Provider. An Identity Provider is a service that must considered as trusted by all services which rely on the issued assertions.
eHealth DSI does not make any assumptions on whether NCP-B or a national service within country B acts as the initial Identity Provider that verifies the identity and authenticity of an HP. The only constraint imposed by eHealth DSI is that NCP-B vouchers for the issued assertions and therefore is considered as the Identity Provider with respect to NCP-A as the assertion consumer.

1.2.3 Relationship to IHE XUA Integration Profile

The IHE Cross-Enterprise User Assertion (XUA) integration profile defines conventions for using SAML identity assertions within healthcare scenarios. For verifying the authenticity and legitimacy of the presenter of an assertion the XUA profile considers both the bearer method and the holder-of-key method. These methods do not match the needs of a trust-brokered environment where the presenter of the assertion is not the subject but vouches for the subject (in eHealth DSI terms: NCP-B vouches for an assertion about the HP-B).
For these kinds of settings, the SAML standard defines the sender-vouches method where a trust relationship exists between the presenter and the consumer of an assertion, but where the subject of the assertions is neither known nor trusted directly by the assertion consumer.
This binding makes use of the sender-vouches confirmation method and therefore is not compliant with the IHE XUA integration profile. Nevertheless, this binding was designed to be as close as possible to the XUA integration profile in order to allow for a maximum re-use of existing products and testing procedures.
Furthermore, all assertions, IdA, NoK and TRC, are only specified for use in intra-NCP communication and interaction patters. Any subsequent re-use may be performed by a MS (Member State) but is not specified as such.

1.3 Related Documents

Requirements and logical level specifications related to this binding are provided in [Interoperability Specification].
The WS Security compliant placement of SAML assertions into the SOAP Header is specified in [Messaging Profile].
eHealth DSI profiles for signature certificates as to be used by NCP-B for signing SAML assertions are provided in [X.509 Certificate Profiles].
Algorithms and key lengths to be used for protecting SAML assertions and derived claims are specified in [Cryptographic Algorithms].

1.4 Conventions

The keywords MUST, SHOULD, MAY, SHOULD NOT and MUST NOT, are used as defined in [RFC 2119].

eHealth DSI related terms (e.g. NCP) are be interpreted as defined in [Interoperability Specification] and [eHealth DSI Glossary].

1.4.1 Data Element Optionality

For indicating the optionality of certain functionalities or data fields the following keywords are used:

- "**R**" or "**Required**": Functionalities and data fields marked as "R" MUST be provided.
- The notation "**R+**" is used to indicate that eHealth DSI is stricter on the mandatory nature of the functionality or data field than the underlying base standard.
- "**O**" or "**Optional**": Functionalities and data fields marked as "O" MAY be omitted.
- "**R/O**": Data fields marked as "R/O" are conditionally mandatory.
- "**X**": Functionalities and data fields marked as "X" MUST NOT be used.

1.4.2 Namespaces

XML namespace prefixes are used in this document to stand for their respective namespaces as follows:

Prefix	Namespace
eHealth DSI	urn:ehdsi
soapenv	http://www.w3.org/2003/05/soap-envelope
wsse	http://docs.oasis-open.org/wss/2004/01/oasis-200401-wss-wssecurity-secext-1.0.xsd
saml	urn:oasis:names:tc:SAML:2.0:assertion
xacml	urn:oasis:names:tc:xacml:2.0:policy:schema:os

1.5 Terms and Definitions

The country which holds information about a patient, where the patient can be univocally identified and where his data may be accessed is called "country-A" (country of affiliation) [eHealth DSI Glossary]. The country of treatment where cross-border health care is provided when the patient is seeking care abroad is called "country-B" (country of care) [eHealth DSI Glossary].

The term "Healthcare Professional (HP)" denotes a doctor of medicine, a nurse responsible for general care, a dental practitioner, a midwife or a pharmacist within the meaning of [Directive 2005/36/EC], or another professional exercising activities in the healthcare sector which are restricted to a regulated profession as defined in Article 3(1)(a) of [Directive 2005/36/EC], or a person considered to be a health professional according to the legislation of the country of treatment [eHealth DSI Glossary]. Health professionals are allowed to process medical patient data according to the legislation of the country of the health professional's residence. An "eHealth DSI Point of Care (PoC)" is a location where an eHealth DSI patient may seek healthcare services [eHealth DSI Glossary].

A "National Contact Point (NCP)" is an entity in each particular country to act as a bidirectional technical, organizational and legal interface between the existing national functions and infrastructures [eHealth DSI Glossary].

In this document the term "NCP" emphasizes the technical aspects of this interface and as such refers to a gateway which facilitates various aspects of cross-border data sharing (e.g. message forwarding, signature verification). From an architectural perspective

NCPs denote the boundary between the eHealth DSI infrastructure and a country's existing national eHealth infrastructure (see [Interoperability Specification] for details).

1.6 Status of this Binding

The binding as defined in this document is a normative binding. All eHealth DSI countries MUST implement this binding within their NCP.
Additional or alternative bindings MUST NOT be defined and implemented for the eHealth DSI.

2 eHealth DSI Professional Identity Assertion

The *HP Identity Assertion* defines a means to communicate a user's assigned identity and its attributes in a trustworthy manner among NCPs. This enables relying parties to run their business tasks without identifying the requester since this is done by a trusted third-party authentication service. On behalf of the "transferrable" claim the relying party can render and enforce access decisions.
Being part of the eHealth DSI security architecture, the national and therefore decentralized identity management produces authentication assertions that are encoded as SAML assertions [OASIS SAML 2.0]. Such an assertion confirms the user's identity, the successful authentication of the user, and the attributes assigned to the user.
The HP Identity Assertion is a profiled SAML v2.0 assertion. It has *Sender-Vouches* (with no additional means to determine if the NCP-A should process the assertion further) configured as the confirmation method with NCP-B vouchering for the HP who is initiating a data transferral transaction between country-B and country-A.

2.1 Generic Structure of the Identity Assertion

The following table specified how the elements and attributes of a SAML v2.0 assertion are to be used about the context of the eHealth DSI Identity Assertion. Elements and attributes which are not explicitly profiled within this table MUST be ignored by the assertion consumer.

Assertion Element	Opt	Usage Convention
@Version	R	MUST be "2.0"
@ID	R	URN encoded unique identifier (UUID) of the assertion
@IssueInstant	R	time instant of issuance in UTC
Issuer	R	address URI that identifies the endpoint of the issuing service (i.e. Uri of NCP-B)
Subject	R	
NameID	R	Identifier of the HP encoded as an X.509 subject name, an e-Mail address or as a string value (unspecified format). NCP-B MUST guarantee that this identifier can be long-term tracked back to an individual person.
@Format	R	MUST be "urn:oasis:names:tc:SAML:1.1:nameid-format:unspecified" or "urn:oasis:names:tc:SAML:1.1:nameid-format:X509SubjectName" or "urn:oasis:names:tc:SAML:1.1:nameid-format:emailAddress"
SubjectConfirmation	R	
@Method	R	MUST be "urn:oasis:names:tc:SAML:2.0:cm:sender-vouches"
SubjectConfirmation Data	X	
Conditions	R	
@NotBefore	R	Time instant from which the assertion is useable. This condition MUST be assessed by the assertion consumer to proof the validity of the assertion. Implementations SHOULD accept assertions that are within

			60 seconds of the validity window boundaries to accommodate clock drift between NCPs.
	AudienceRestriction	R	
	Audience	R	This element of the assertion should contain a value identifying the X-Service Provider. The value represents an URI that identifies the Affinity Domain of the receiver e.g., <Audience> urn:ehdsi:assertions.audience:x-border<Audience>
	@NotOnOrAfter	R	Time instant at which the assertion expires. This condition MUST be assessed by the assertion consumer to proof the validity of the assertion. The maximum validity timespan for an HP Identity Assertion MUST NOT be more than 4 hours. Implementations SHOULD accept assertions that are within 60 seconds of the validity window boundaries to accommodate clock drift between NCPs.
AuthnStatement		R	
	@AuthnInstant	R	Time instant of HP authentication in UTC
	@SessionNotOnOrAfter	O	Time instant of the expiration of the session
	AuthnContext	R	
	AuthnContextClassRef	R	Reference to the HP authentication method, Two-Factor Authentication method MUST be used: See [OASIS SAML Authn] for a list of valid authentication methods: • urn:oasis:names:tc:SAML:2.0:ac:classes:MobileTwoFactorUnregistered • urn:oasis:names:tc:SAML:2.0:ac:classes:MobileTwoFactorContract • urn:oasis:names:tc:SAML:2.0:ac:classes:X509 • urn:oasis:names:tc:SAML:2.0:ac:classes:SPKI • urn:oasis:names:tc:SAML:2.0:ac:classes:SmartcardPKI • urn:oasis:names:tc:SAML:2.0:ac:classes:SoftwarePKI • urn:oasis:names:tc:SAML:2.0:ac:classes:TLSClient
AttributeStatement		R	HP identity attributes and permissions (see sections 2.3 and 2.4)
ds:Signature		R	Enveloped XML signature of the issuer of the HP Identity Assertion (i.e., the NCP-B) (see section 2.2)

Assertion consumers MUST reject any HCP Identity Assertion that contains a SubjectConfirmationData element, so that the prohibition is enforceable and not just a table annotation.

2.2 Assertion Signature

Every HP Identity Assertion MUST be signed by its issuer (i.e. the NCP-B). The XML signature MUST be applied by using the *saml:Assertion/ds:Signature* element as defined in [Cryptographic Algorithms].

2.3 HP Identity Attributes

An identity assertion can carry an arbitrary number of attributes on the authenticated entity. Each attribute MUST be encoded using a SAML *attribute* element.
For eHealth DSI the following attribute names and catalogues are defined.

HCI Identifier	
Name:	urn:ihe:iti:xca:2010:homeCommunityId
Values:	ID of the Home Community
Type	String
Optionality:	Mandatory
Description:	This attribute is used to identify the organization or "home community" that is responsible for the information contained in a SAML assertion, such as an electronic health record (EHR) system. The value of the attribute is a unique identifier, such as a URN or OID, that is assigned by a recognized authority, such as a national or regional health information organization.
NPI Identifier	
Name:	urn:oasis:names:tc:xspa:1.0:subject:npi

Values:	National Provider Identifier
Type	String
Optionality:	Optional
Description:	This attribute MUST contain the National Provider Identifier (NPI). National Provider Identifier (NPI) is a unique identifier assigned to healthcare providers by their national authority and it can be included as an attribute in a SAML 2.0 assertion to uniquely identify a healthcare provider and to authenticate and authorize their access to specific resources. The format of the NPI Identifier in a SAML assertion is typically a 10-digit number.
HP Identifier	
FriendlyName:	XSPA Subject
Name:	urn:oasis:names:tc:xspa:1.0:subject:subject-id
Values:	Human readable name of the HP
Type	String
Optionality:	Mandatory
Description:	This attribute MUST contain the full name of the HP.

Structural Role of the HP	
FriendlyName:	XSPA Role
Name:	urn:oasis:names:tc:xacml:2.0:subject:role
Values:	Based on eHDSI mutual agreement a subset of ISCO Code System (2.16.840.1.113883.2.9.6.2.7) SHALL be used represented by the following list: "221 Medical Doctors", "2221 - Nursing professionals", "2222 - Midwifery professionals", "2262 - Pharmacists", "3213 - Pharmaceutical technicians and assistants", "2261 - Dentists", "2264 - Physiotherapists", "2265 - Dieticians and nutritionists", "2266 - Audiologists and speech therapists", "2267 - Optometrists and ophthalmic opticians", "3211 - Medical imaging and therapeutic equipment technicians", "2269 - Health professionals not elsewhere classified" and "44 - Other Clerical Support Workers". Changes from Revision 19.0 states that the Role SHALL be recorded under the AttributeValue with an element <Role> in the namespace ‚urn:hl7-org:v3‘, whose content is defined by the CE datatypes from HL7V3
Type	String
Optionality:	Mandatory
Speciality of the HP	
FriendlyName:	HITSP Clinical Speciality
Name:	urn:ehdsi:names:wp3.4:subject:clinical-speciality
Values:	SNOMED CT based value set 2.16.840.1.113883.3.88.12.80.72 as defined in [HITSP C80 2.0]. See table 2-149 in [HITSP C80 2.0] for the full list of possible values.
Type:	String
Optionality:	Optional
Permissions acc. To the legislation of the country of care (country B)	
FriendlyName:	XSPA permissions according with HL7
Name:	urn:oasis:names:tc:xspa:1.0:subject:hl7:permission
Values:	See section 3.4 of this document
Type:	URI
Optionality:	Optional. If no permissions are given, only the permissions of the HP structural role acc. To the legislation of the country of affiliation (country A) are considered for the access control decision. If permissions are defined, the country of affiliation SHOULD consider these for all access control decisions.
Delegated Rights	
FriendlyName:	OnBehalfOf
Name:	urn:ehdsi:names:subject:on-behalf-of
Values:	Based on eHDSI mutual agreement a subset if ISCO Code System SHALL be used represented by the following list: “221 Medical Doctors”, “2221 – Nursing professionals”, “2222 – Midwifery professionals”, “2262 – Pharmacists”, “3213 – Pharmaceutical technicians and assistants”, “2261 – Dentists”, “2264 – Physiotherapists”, “2265 – Dieticians and nutritionists”, “2266 – Audiologists and speech therapists”, “2267 – Optometrists and ophthalmic opticians”, “3211 – Medical imaging and therapeutic equipment technicians”, “2269 – Health professionals not elsewhere classified” and “44 - Other Clerical Support Workers".
Type:	String
Optionality:	Mandatory if a structural role is part of the category "Clerical Support Workers" is presented. For all other structural roles, this attribute is optional.

Description	If a person is acting on behalf of another person, the role of this person MAY be provided with this attribute. If this attribute is included with a HP identity assertion, the issuer of the assertion MUST be able to track back the delegation to the two natural persons involved. Only valid roles as defined for HP structural roles MUST be used. An assertion consumer MAY decide not to accept delegated access rights by just ignoring this attribute.
Healthcare Professional Organisation	
FriendlyName:	XSPA Organization
Name:	urn:oasis:names:tc:xspa:1.0:subject:organization
Values:	Name of the HealthCare Professional Organisation
Type:	String
Optionality:	Optional
Description	This value SHOULD only be provided if different from the point of care (e.g., in cases where a hospital organization runs multiple points of care or where a hospital just provides a professional environment for otherwise independent care providers)
Healthcare Professional Organisation ID	
FriendlyName:	XSPA Organization Id
Name:	urn:oasis:names:tc:xspa:1.0:subject:organization-id
Values:	URN encoded UID of the Healthcare Professional Organisation
Type:	String
Optionality:	Mandatory
Description:	This value SHALL be an OID (urn:oid:1.2.3.4) or HL7II (urn:hl7ii:1.2.3.4:XYZ) depending of the National requirements.
Type of HCPO	
FriendlyName:	eHealth DSI Healthcare Facility Type
Name:	urn:ehdsi:names:subject:healthcare-facility-type
Values:	eHealth DSI code list1.3.6.1.4.1.12559.11.10.1.3.2.2.2. Possible values are: "Hospital", "Resident Physician", "Pharmacy", "Other".
Type:	String
Optionality:	Mandatory
Description	If a healthcare facility is not operated under the supervision of a physician or pharmacist, the healthcare facility type MUST be set to "Other".
Purpose of Use	
FriendlyName:	XSPA Purpose of Use
Name:	urn:oasis:names:tc:xspa:1.0:subject:purposeofuse
Values:	For eHealth DSI only following values are allowed: • TREATMENT: perform one or more operations, when patient in condition of providing confirmation of his will, to retrieve information for provision of health care • EMERGENCY: perform one or more operations, when patient is unconscious or in the impossibility of confirming his will, to retrieve information for provision of immediately needed health care for an emergent condition (“breaking the glass") are allowed as purpose of use. If a HP requests claims for another purpose of use, the request must be rejected as unauthorized. Changes from Revision 19.0 states that Purpose of use shall be presented with an element <PurposeOfUse> under the element AttributeValue., and shall have the namespace'urn:hl7-org:v3' whose content is defined by the 'CE' HL7V3 datatypes. As no specific Code System were considered to be used, a temporary one can be used: “eHDSI PurposeOfUse” with identifier “3bc18518-d305-46c2-a8d6-94bd59856e9e” and code “EMERGENCY” or “TREATMENT”
Optionality:	Mandatory
Description	As the HP identity assertion is independent of a specific patient’s treatment, this attribute refers to the usual working environment of the user.
Point of Care	
FriendlyName:	XSPA Locality
Name:	urn:oasis:names:tc:xspa:1.0:environment:locality
Type:	String
Optionality:	Mandatory
Description	Name of the hospital or medical facility where patient care takes place.

Any attributes not listed in this list MAY be ignored by the assertion consumer.

2.4 Audit Trail Consideration

Both NCP-B and NCP-A MUST write an audit trail entry (ITI-40) for the confirmation of a Healthcare Provider identification (e.g. after the attesting signature has been applied to the Treatment Relationship Confirmation Assertion). The audit message

MUST be assembled according to the HP Assurance audit schema as defined in [Audit Trail Profile]. The following table defines which categories MUST be filled (R), which MAY be filled (O) and which categories MUST NOT be used (X).

eHealth DSI Instance	Opt.	Description
Event	R	Audited event
Requesting Point of Care	R	HCPO which is in a treatment relationship with the patient
Human Requestor	R	HP who requested the confirmation of the treatment relationship
Source Gateway	R	Outbound gateway that attested the authenticity of the Treatment Relationship Confirmation Assertion
Target Gateway	X	
Audit Source	R	Legal entity that ensures the uniqueness of the identifiers that are uses to identify active participants
Patient	R	Patient who is in a treatment relationship with the HCPO
Event Target	X	

2.5 Permission Codes

The eHealth DSI access control paradigm follows the "needs to know" principle by respecting the role and task definitions and derived permissions that a HP is assigned in the country of care. As these permissions can only be defined and assigned by the HPs local legal context, they are transmitted to the patient's country of affiliation as part of the HP identity assertion.
For the recently defined eHealth DSI use cases the following permission codes as defined in the context of HL7's role engineering are of interest:

Permission	Description
POE-006	Change/Discontinue/Refill Outpatient Prescription Order
PRD-003	Review Medical History
PRD-004	Review Existing Orders
PRD-005	Review Vital Signs/Patient Measurements
PRD-006	Patient Identification and Lookup
PRD-010	Review Patient Medications
PRD-016	Review Problem List
PPD-029	New Discharge Summary
PPD-032	New Consents and Authorizations
PPD-033	Edit/Addend/Sign Consents and Authorizations
PPD-046	Record Medication Administration Record

The following matrix shows which permissions MUST at least be assigned to an HP to perform the defined eHealth DSI operations.

eHealth DSI Use Case	Minimum Permissions
Patient Identification	PRD-006
Request for Patient Summary	PRD-003 and PRD-005 and PRD-010 and PRD-016
Request for ePrescriptions	PRD-004 and PRD-010
Request for Medication Summary	PRD-010
Request for Original Clinical Document	PRD-003 and PRD-005 and PRD-010 and PRD-016
Request for Laboratory Result Report	PRD-004
Request for Hospital Discharge Report	PRD-003 and PRD-005 and PRD-010 and PRD-016
Writing/Sending of Hospital Discharge Report	PPD-029
Request for Medical Imaging Study	PRD-004
Request for Medical Imaging Report	PRD-004
Notification on Dispensation	PPD-046
Notification on Dispensation Discard	PPD-046
New Consent given in Country-B	PPD-032
Consent Revocation in Country-B	PPD-033

3 Next of Kin Identity Assertion

The Next of Kin Assertion is a profiled SAML v2.0 assertion. It attests the request of a next of kin to access patient data.

3.1 Generic Structure of the Next of Kin Assertion

Assertion Element	Opt	Usage Convention
@Version	R	MUST be "2.0"
@ID	R	URN encoded unique identifier (UUID) of the assertion
@IssueInstant	R	time instant of issuance in UTC
Issuer	R	address URI that identifies the endpoint of the issuing service (e.g., it may be the URI of NCP-B, as the issuer of the IdA)
Subject	R	
NameID	R	Identifier of the health professional encoded as an X.509 subject name, an e-Mail address or as a string value (unspecified format). The same identifier and encoding MUST be used as for the referenced HP Identity Assertion.
@Format	R	MUST be "urn:oasis:names:tc:SAML:1.1:nameid-format:unspecified" or "urn:oasis:names:tc:SAML:1.1:nameid-format:X509SubjectName" or "urn:oasis:names:tc:SAML:1.1:nameid-format:emailAddress"
SubjectConfirmation	R	
@Method	R	MUST be "urn:oasis:names:tc:SAML:2.0:cm:sender-vouches"
Conditions	R	
@NotBefore	R	Time instant from which the assertion is useable. This condition MUST be assessed by the assertion consumer to proof the validity of the assertion. Implementations SHOULD accept assertions that are within 60 seconds of the validity window boundaries to accommodate clock drift between NCPs.
AudienceRestriction	R	
Audience	R	This element of the assertion should contain a value identifying the X-Service Provider. The value represents an URI that identifies the Affinity Domain of the receiver e.g. <Audience>urn:ehdsi:assertions.audience:x-border<Audience>
@NotOnOrAfter	R	Time instant at which the assertion expires. This condition MUST be assessed by the assertion consumer to proof the validity of the assertion. The maximum validity timespan for a Next of Kin Assertion MUST NOT be more than 2 hours. Implementations SHOULD accept assertions that are within 60 seconds of the validity window boundaries to accommodate clock drift between NCPs.
Advice	R	
AssertionIdRef	R	Reference to the HP identity assertion that provides information on the HP and the healthcare facility that were authorised by the patient to access his medical data
AuthnStatement	R	
@AuthnInstant	R	Time instant of authentication in UTC
@SessionNotOnOrAfter	O	Time instant of the expiration of the session
AuthnContext	R	
AuthnContextClassRef	R	For TRC and NOK it MUST be "urn:oasis:names:tc:SAML:2.0:ac:classes:PreviousSession"
AttributeStatement	R	Next of Kin identity attributes and treatment context information (see section 3.3)
ds:Signature	R	Signature of the issuer (e.g., NCP-B) of the Next of Kin Assertion (see section 3.2)

3.2 Assertion Signature

Every Next of Kin Assertion MUST be signed by its issuer. For the NoK assertion, it MAY be the NCP-B. The XML signature MUST be applied by using the *saml:Assertion/ds:Signature* element as defined in [Cryptographic Algorithms].

3.3 Next of Kin Attributes

A Next of Kin assertion can carry an arbitrary number of attributes on the guardian to be identified and the relationship with the patient. Each attribute MUST be encoded using a SAML attribute element.

Patient Identifier	
FriendlyName:	XSPA subject
Name:	urn:oasis:names:tc:xspa:1.0:subject:subject-id
Values:	URI encoded identifier of the Next of Kin as obtained by the id traits handshake
Type	urn:oasis:names:tc:SAML:2.0:attrname-format:uri
Optionality:	Mandatory
Purpose of Use	
FriendlyName:	XSPA Purpose Of Use
Name:	urn:oasis:names:tc:xspa:1.0:subject:purposeofuse
Values:	For eHealth DSI only following values are allowed: • TREATMENT: perform one or more operations, when patient is in condition of providing confirmation of his will, to retrieve information for provision of health care • EMERGENCY: perform one or more operations, when patient is unconscious or in the impossibility of confirming his will, to retrieve information for provision of immediately needed health care for an emergent condition. In the case of the Next of Kin the EMERGENCY purpose of use is redundant as the Next of Kin give consent on behalf of the patient if unconscious and release the HP of the responsibility of having “broken the glass”. are allowed as purpose of use. If a requests claims for another purpose of use, the request must be rejected as unauthorized. Changes from Revision 19.0 states that Purpose of use shall be presented with an element <PurposeOfUse> under the element AttributeValue., and shall have the namespace'urn:hl7-org:v3' whose content is defined by the 'CE' HL7V3 datatypes. As no specific Code System were considered to be used, a temporary one can be used: “eHDSI PurposeOfUse” with identifier “3bc18518-d305-46c2-a8d6-94bd59856e9e” and code “EMERGENCY” or “TREATMENT”
Optionality:	Optional
Description	If this attribute is present, it overwrites the purpose of use attribute contained with the HP identity assertion.

Apart from the attributes mentioned above, specific Next of Kin attributes are defined based on the identification traits outlined in the eHDSI-ism schema (with each trait represented as a separate element).

These attributes SHOULD follow the format:
urn:ehdsi:names:subject:nextofkin:xxxx.

For eHealth DSI the following attribute names are defined.

Next of Kin id	
FriendlyName:	NextOfKinId
Name:	urn:ehdsi:names:subject:nextofkin:id
Values:	URI encoded identifier of the Next of Kin id that identifies the next of kin requesting access to the patient information.
Type	urn:oasis:names:tc:SAML:2.0:attrname-format:uri
Optionality:	Mandatory
Description:	This attribute provides information related to the Next of Kin requesting access to the patient information, presented as an id
Next of Kin firstname	
FriendlyName:	NextOfKinFirstName
Name:	urn:ehdsi:names:subject:nextofkin:firstname
Values:	String representing the next of kin’s firstname.
Type	urn:oasis:names:tc:SAML:2.0:attrname-format:uri

Optionality:	Optional
Description:	The next of kin's firstname

Next of Kin familyname

FriendlyName:	NextOfKinFamilyName
Name:	urn:ehdsi:names:subject:nextofkin:familyname
Values:	String representing the next of kin's familyname.
Type	urn:oasis:names:tc:SAML:2.0:attrname-format:uri
Optionality:	Optional
Description:	The next of kin's familyname

Next of Kin gender

FriendlyName:	NextOfKinGender
Name:	urn:ehdsi:names:subject:nextofkin:gender
Values:	String representing the next of kin's gender.
Type	urn:oasis:names:tc:SAML:2.0:attrname-format:uri
Optionality:	Optional
Description:	The next of kin's lastname

Next of Kin birthdate

FriendlyName:	NextOfKinBirthDate
Name:	urn:ehdsi:names:subject:nextofkin:birthdate
Values:	String representing the next of kin's birthdate.
Type	urn:oasis:names:tc:SAML:2.0:attrname-format:uri
Optionality:	Optional
Description:	The next of kin's birthdate

Next of Kin address street

FriendlyName:	NextOfKinAddressStreet
Name:	urn:ehdsi:names:subject:nextofkin:address:street
Values:	String representing the next of kin's address street.
Type	urn:oasis:names:tc:SAML:2.0:attrname-format:uri
Optionality:	Optional
Description:	The next of kin's address street

Next of Kin address city

FriendlyName:	NextOfKinAddressCity
Name:	urn:ehdsi:names:subject:nextofkin:address:city
Values:	String representing the next of kin's address city.
Type	urn:oasis:names:tc:SAML:2.0:attrname-format:uri
Optionality:	Optional
Description:	The next of kin's address city

Next of Kin address postalcode

FriendlyName:	NextOfKinPostalCode
Name:	urn:ehdsi:names:subject:nextofkin:address:postalcode
Values:	String representing the next of kin's address postalcode.
Type	urn:oasis:names:tc:SAML:2.0:attrname-format:uri
Optionality:	Optional
Description:	The next of kin's address postalcode

Next of Kin address country

FriendlyName:	NextOfKinAddressCountry
Name:	urn:ehdsi:names:subject:nextofkin:address:country
Values:	String representing the next of kin's address country.
Type	urn:oasis:names:tc:SAML:2.0:attrname-format:uri
Optionality:	Optional

Description:	The next of kin's address country.

3.4 Audit Trail Consideration

The NCP MUST write an audit trail entry for the confirmation of a Next of Kin relationship (e.g. after the attesting signature has been applied to the Next of Kiin Assertion). The audit message MUST be assembled according to the HP Assurance audit schema as defined in [Audit Trail Profile]. The following table defines which categories MUST be filled (R), which MAY be filled (O) and which categories MUST NOT be used (X).

eHealth DSI Instance	Opt.	Description
Event	R	Audited event
Requesting Point of Care	R	HCPO which is in a treatment relationship with the patient
Human Requestor	R	HP who requested the confirmation of the treatment relationship
Source Gateway	R	Outbound gateway that attested the authenticity of the Next of Kin Assertion
Target Gateway	X	
Audit Source	R	Legal entity that ensures the uniqueness of the identifiers that are uses to identify active participants
Patient	R	Identification traits of the Next of Kin
Event Target	X	

4 Treatment Relationship Confirmation Assertion

The Confirmation Assertion is a profiled SAML v2.0 assertion. It attests the existence of a treatment relationship between a patient and a HCPO and provides information about the context of a certain treatment scenario.

4.1 Generic Structure of the Treatment Relationship Assertion

The eHealth DSI Confirmation Assertion is encoded as a SAML 2.0 assertion. The following restrictions and recommendations apply:

Assertion Element	Opt	Usage Convention
@Version	R	MUST be "2.0"
@ID	R	URN encoded unique identifier (UUID) of the assertion
@IssueInstant	R	time instant of issuance in UTC
Issuer	R	address URI that identifies the endpoint of the issuing service (e.g., it may be the URI of NCP-B, as the issuer of the IdA)
Subject	R	
NameID	R	Identifier of the health professional encoded as an X.509 subject name, an e-Mail address or as a string value (unspecified format). The same identifier and encoding MUST be used as for the referenced HP Identity Assertion.
@Format	R	MUST be "urn:oasis:names:tc:SAML:1.1:nameid-format:unspecified" or "urn:oasis:names:tc:SAML:1.1:nameid-format:X509SubjectName" or "urn:oasis:names:tc:SAML:1.1:nameid-format:emailAddress"
SubjectConfirmation	R	
@Method	R	MUST be "urn:oasis:names:tc:SAML:2.0:cm:sender-vouches"
Conditions	R	
@NotBefore	R	Time instant from which the assertion is useable. This condition MUST be assessed by the assertion consumer to proof the validity of the assertion. Implementations SHOULD accept assertions that are within 60 seconds of the validity window boundaries to accommodate clock drift between NCPs.
AudienceRestriction	R	

	Audience	R	This element of the assertion should contain a value identifying the X-Service Provider. The value represents an URI that identifies the Affinity Domain of the receiver e.g., <Audience> urn:ehdsi:assertions.audience:x-border<Audience>
	@NotOnOrAfter	R	Time instant at which the assertion expires. This condition MUST be assessed by the assertion consumer to proof the validity of the assertion. The maximum validity timespan for a Treatment Relationship Confirmation Assertion MUST NOT be more than 2 hours. Implementations SHOULD accept assertions that are within 60 seconds of the validity window boundaries to accommodate clock drift between NCPs.
Advice		R	
	AssertionIdRef	R	Reference to the HP identity assertion that provides information on the HP and the healthcare facility that were authorised by the patient to access his medical data
AuthnStatement		R	
	@AuthnInstant	R	Time instant of authentication in UTC
	@SessionNotOnOrAfter	O	Time instant of the expiration of the session
	AuthnContext	R	
		AuthnContextClassRef	R	For TRC and NOK it MUST be "urn:oasis:names:tc:SAML:2.0:ac:classes:PreviousSession"
AttributeStatement		R	Patient identity attributes and treatment context information (see section 3.3)
ds:Signature		R	Signature of the issuer (e.g., NCP-B) of the Treatment Relationship Conformation Assertion (see section 3.2)

4.2 Assertion Signature

Every Treatment Relationship Confirmation Assertion MUST be signed by its issuer. For the TRC assertion, it MAY be the NCP-B. The XML signature MUST be applied by using the *saml:Assertion/ds:Signature* element as defined in [Cryptographic Algorithms].

4.3 Patient Identity and Treatment Context Attributes

A Treatment Relationship Confirmation assertion can carry an arbitrary number of attributes on the identified patient and the current treatment context. Each attribute MUST be encoded using a SAML attribute element. For eHealth DSI the following attribute names and catalogues are defined.

Document Identifiers	
FriendlyName:	eHDSI Document Identifiers
Name:	urn:ehdsi:names:document:document-id
Values:	URI encoded identifier of the patient as obtained by the id traits handshake
Type	urn:oasis:names:tc:SAML:2.0:attrname-format:uri
Optionality:	Optional
Description:	If this attribute is present, it provides additional information related to the document access like document ID and Pin Code. They might be presented according following format: urn:ehdsi:names:document:document-id:documentId:XXXX and/or urn:ehdsi:names:document:document-id:pinCode:XXXX
Patient Identifier	
FriendlyName:	XSPA subject
Name:	urn:oasis:names:tc:xspa:1.0:subject:subject-id
Values:	URI encoded identifier of the patient as obtained by the id traits handshake
Type	urn:oasis:names:tc:SAML:2.0:attrname-format:uri
Optionality:	Mandatory
Purpose of Use	
FriendlyName:	XSPA Purpose Of Use
Name:	urn:oasis:names:tc:xspa:1.0:subject:purposeofuse
Values:	For eHealth DSI only following values are allowed: • TREATMENT: perform one or more operations, when patient is in condition of providing confirmation of his will, to retrieve information for provision of health care

	• EMERGENCY: perform one or more operations, when patient is unconscious or in the impossibility of confirming his will, to retrieve information for provision of immediately needed health care for an emergent condition (“breaking the glass")
	are allowed as purpose of use. If a requests claims for another purpose of use, the request must be rejected as unauthorized. Changes from Revision 19.0 states that Purpose of use shall be presented with an element <PurposeOfUse> under the element AttributeValue., and shall have the namespace'urn:hl7-org:v3' whose content is defined by the 'CE' HL7V3 datatypes. As no specific Code System were considered to be used, a temporary one can be used: “eHDSI PurposeofUse” with identifier “3bc18518-d305-46c2-a8d6-94bd59856e9e” and code “EMERGENCY” or “TREATMENT”
Optionality:	Optional
Description	If this attribute is present, it overwrites the purpose of use attribute contained with the HP identity assertion.

4.4 EUDI Wallet PID Sourcing Attributes (CP090)

When the patient identifier included in the Treatment Relationship Confirmation (TRC) Assertion has been obtained via an EUDI Wallet PID presentation — rather than through manual HP entry — two additional optional attributes MUST be included in the TRC AttributeStatement to convey the provenance and trust context of the identifier.

These attributes enable NCP-A to distinguish EUDI-sourced identifiers from manually entered ones and to apply appropriate trust level policies. NCP-A implementations that do not yet support these attributes MUST silently ignore them in accordance with the general rule that unrecognised attributes MAY be ignored by assertion consumers.

Patiend ID Source	
FriendlyName:	eHDSI Patient ID Source
Name:	urn:ehdsi:names:subject:patient-id-source
Values:	EUDI_WALLET_PID | MANUAL_ENTRY
Type	urn:oasis:names:tc:SAML:2.0:attrname-format:uri
Optionality:	R/O — MUST be present when patient identifier was obtained via EUDI Wallet PID presentation. MUST be absent or set to MANUAL_ENTRY in all other cases.
Description:	Indicates the mechanism by which the patient identifier included in the urn:oasis:names:tc:xspa:1.0:subject:subject-id attribute was obtained. When set to EUDI_WALLET_PID, the NCP-B asserts that the identifier was extracted from a cryptographically verified PID credential presented by the patient from their EUDI Wallet app. The NCP-B MUST have completed all VP Token validation steps before setting this value.
PID Issuer Country	
FriendlyName:	eHDSI PID Issuer Country
Name:	urn:ehdsi:names:subject:pid-issuer-country
Values:	ISO 3166-1 alpha-2 country code (e.g. BE, IT, DE, FR)
Type	urn:oasis:names:tc:SAML:2.0:attrname-format:uri
Optionality:	R/O — MUST be present when patient-id-source = EUDI_WALLET_PID. MUST be absent otherwise.
Description:	The ISO 3166-1 alpha-2 country code of the member state that issued the PID credential presented by the patient. This value is derived from the country attribute of the PID issuer certificate, which must have been validated against the EU Trusted List as part of VP Token validation. NCP-A MAY use this attribute to select the appropriate national patient identifier assigning authority OID for the LivingSubjectId resolution.

4.5 Audit Trail Consideration

The NCP MUST write an audit trail entry for the confirmation of a treatment relationship (e.g. after the attesting signature has been applied to the Treatment Relationship Confirmation Assertion). The audit message MUST be assembled according to the HP Assurance audit schema as defined in [Audit Trail Profile]. The

following table defines which categories MUST be filled (R), which MAY be filled (O) and which categories MUST NOT be used (X).

eHealth DSI Instance	Opt.	Description
Event	R	Audited event
Requesting Point of Care	R	HCPO which is in a treatment relationship with the patient
Human Requestor	R	HP who requested the confirmation of the treatment relationship
Source Gateway	R	Outbound gateway that attested the authenticity of the Treatment Relationship Confirmation Assertion
Target Gateway	X	
Audit Source	R	Legal entity that ensures the uniqueness of the identifiers that are uses to identify active participants
Patient	R	Patient who is in a treatment relationship with the HCPO
Event Target	X	

Table 1: Country-B NCP Audit Message Categories

5 References

5.1 Normative References

[OASIS SAML 2.0] OASIS Security Services TC: Assertions and Protocols for the OASIS Security Assertion Markup Language version 2.0. http://docs.oasis-open.org/security/saml/v2.0/saml-core-2.0-os.pdf

[RFC 2119] Bradner, S.: Key words for use in RFCs to Indicate Requirement Levels. Harvard University, Boston, Massachusetts, 1997.

5.2 Non-Normative References (IHE XUA Profile)

[HITSP C80 2.0] HITSP: Clinical Document and Message Terminology Component. Version 2.0. http://www.hitsp.org/Handlers/HitspFileServer.aspx?FileGuid=886331bd-2eba-4ded-a1ed-24b35ecebb62

[IHE WP AC] IHE International: IHE IT Infrastructure Technical Framework. June 2009. http://www.ihe.net/Technical_Framework/upload/IHE_ITI_TF_WhitePaper_AccessControl_2009-09-28.pdf

[OASIS SAML Authn] J. Kemp et al. (Eds.): Authentication Context for the OASIS Security Assertion Markup Language (SAML) V2.0, 2005. https://docs.oasis-open.org/security/saml/v2.0/saml-authn-context-2.0-os.pdf

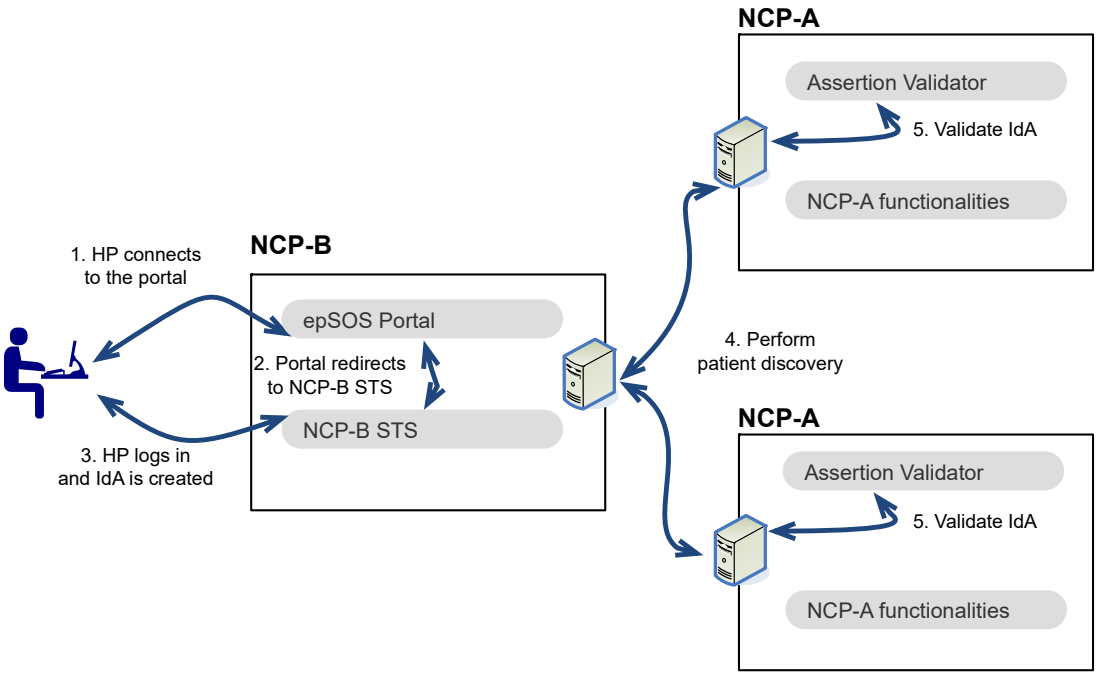
[OASIS SAML Profiles] J. Hughes et al. (Eds.): Profiles for the OASIS Security Assertion Markup Language (SAML) V2.0, 2005. http://docs.oasis-open.org/security/saml/v2.0/saml-profiles-2.0-os.pdf

[WS Security] A. Nadalin et al. (Eds.), Web Service Security: SOAP Message Security 1.1, 2006.

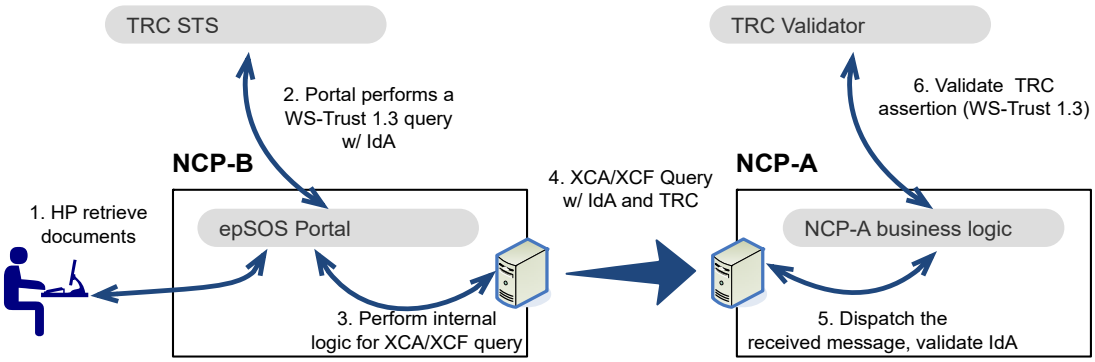
[WS Trust] A. Nadalin et al. (Eds.), WS-Trust 1.3, 2007.

6 eHealth DSI Common Component Specification (non-normative)

NCP-B and the corresponding national infrastructure are required to deploy two security token services (STSs): the eHealth DSI Identity Provider (NCP-B STS), which is responsible to issue the eHealth DSI Identity Assertion and the NoK Assertion. And the TRC-STS, which is responsible the TRC Assertion after a patient has been discovered and the identity assertion has been issued, used as session supporting token.



In the typical eHealth DSI-portal deployment the HP contacts the portal (the Service Provider), which redirects the HP to the NCP-B STS, by using the SAMLv2 HTTP-POST Web Browser SSO profile [OASIS SAML Profiles]. The NCP-B STS authenticates the HP1 and returns the control to the eHealth DSI Portal. During this process, the eHealth DSI Identity Assertion (IdA) is created. At this time, the HP performs a patient discovery against the selected NCP-A, an XCPD query with the IdA and the optional NoK as supporting token. The remote NCP-A will firstly validate the IdA, secondly will enforce an access control policies based on the information of the IdA's attribute statement.



After a successful patient discovery, the HP retrieves documents. The eHealth DSI portal asks for the treatment relationship confirmation and calls the TRC-STS, using a

[1] Authentication methods are left unspecified by eHealth DSI and they are under the national legislation. The usage Level of Authentication (LoA) is mandatory.

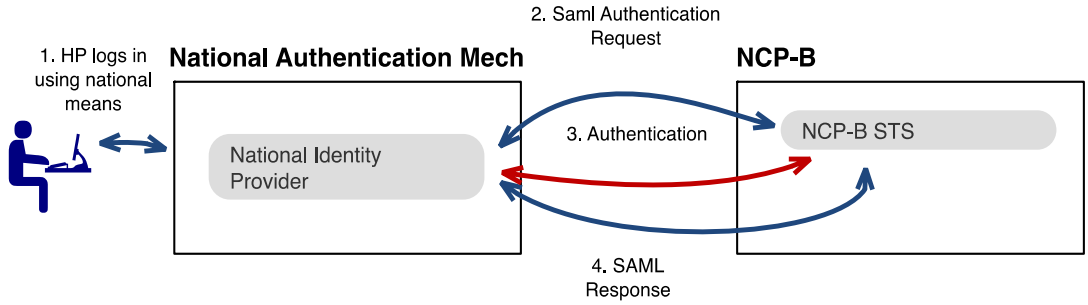
WS-Trust 1.3 RequestSecurityToken (RST) message. TRC-STS validates the IdA contained in the RST and issues the TRC Assertion. The portal prepares the XCA/ query to be sent to NCP-A with the IdA, optional NoK and TRC assertions as supporting tokens.
All the assertions are placed in the messages using WS-Security-1.1 [WS Security]. NCP-A receives the message, dispatches it, validates the IdA, NoK and the TRC, and performs business logic. The TRC Validator and the TRC-STS are outside the trust zone of the NCP, and they SHALL be deployed under the national legislation.

6.1 NCP-B STS specification

6.1.1 SAML HTTP-POST Web Browser SSO

Operation	eHealth DSI Portal Login
Description	Obtain an eHealth DSI Identity Assertion by using a portal-based service provider
Requester	eHealth DSI Portal
Standard Used	SAMLv2 HTTP-POST Web Browser SSO
Input Message	A signed SAMLv2 Authentication Request • Protocol binding: urn:oasis:names:tc:SAML:2.0:bindings:HTTP-POST • The request SHALL have a time validity • All timestamps MUST be in UTC • Signature MUST be made using the service provider key
Output Message in Successful case	A Signed SAMLv2 Response • The response SHALL contain a Status with value #Success • The response SHALL contain an IssueInstant • The response SHALL contain the IdA • The response SHALL contain an Issuer • The signature SHALL be made using the NCP-B STS key
Main success scenario	After receiving the SAML authentication request, the Identity Provider performs the validation. If the signature is valid, and the conditions are fulfilled, the identity provider SHALL authenticate the user. After a successful authentication, the Identity Provider issues the IdA, and the SAML Response containing. The Service Provider, after receiving the SAML Response, validates the signature and the condition

It is worth noticing that this approach is not restricted to the direct interaction with the HP. The requester can also be a software actor acting on behalf of an already authenticated principal, as shown in the picture below.



6.1.2 NCP-B STS Specification: WS-Trust

Operation	Obtain a new IdA
Description	Obtain a new IdA using WS-Trust 1.3
Requester	National Infrastructure

Standard Used	WS-Trust 1.3 [WS Trust]
Input Message	The input message SHALL be a WS-Trust 1.3 *RequestSecurityToken.* • WS-Addressing or SOAP action http://docs.oasis-open.org/ws-sx/ws-trust/200512/RST/Issue • Request Type http://docs.oasis-open.org/ws-sx/ws-trust/200512/Issue • Token Type http://docs.oasis-open.org/wss/oasis-wss-saml-token-profile-1.1#SAMLV2.0
Output Message	The output message is a WS-Trust 1.3 *RequestSecurityTokenResponseCollection (RSTRC)* containing a single *RequestSecurityTokenResponse* containing a single *RequestedSecurityToken* containing the IdA
Main Success Scenario	After receiving the RST from a trusted and authenticated client, the NCP-B STS issues the eHealth DSI Identity Assertion

6.1.3 NCP-A's STS: Validate an IdA

Located in NCP-A, this STS will process validation requests for eHealth DSI Identity Assertions.

Operation	Validate an eHealth DSI IdA
Description	The NCP-A's STS validates the IdA used as supporting token for a generic eHealth DSI transaction
Requester	NCP-A internal business logic
Standard Used	WS-Trust 1.3
Input Message	The input message SHALL be a WS-Trust 1.3 *RequestSecurityToken* • WS-Addressing or SOAP action http://docs.oasis-open.org/ws-sx/ws-trust/200512/RST/Validate • Request Type http://docs.oasis-open.org/ws-sx/ws-trust/200512/Validate • Token Type http://docs.oasis-open.org/wss/oasis-wss-saml-token-profile-1.1#SAMLV2.0 • The SOAP Security Header SHALL contain the eHealth DSI IdA as described in [WS-Security] • The *ValidateTarget* element SHALL contain a *wsse:SecurityTokenReference* and its *Reference* URI SHALL be the ID of the IdA.
Output Message	The output message SHALL be a WS-Trust 1.3 *RequestSecurityTokenResponseCollection* containing a *Status* and a *Code*
Main Success Scenario	The STS receives the token validation request. After that it processes the referenced IdA and validates the signature, conditions, and other means. If the validation succeeds, the RST responds with the output message where the status code is http://docs.oasis-open.org/ws-sx/ws-trust/200512/status/valid

6.2 TRC-STS: Issue a new TRC Assertion

The TRC-STS re-uses the eHealth DSI IdA's session to create the TRC Assertion, using WS-Trust. It needs to know the PurposeOfUse (e.g., the reason why this TRC assertion is created) and the patient ID under treatment.

Operation	Issue a TRC Assertion
Description	Issue a TRC assertion with a specific Purpose and for a specific Patient
Requester	NCP-B
Standard Used	WS-Trust 1.3 [WS Trust]
Input Message	A WS-Trust 1.3 *RequestSecurityToken* • WS-Addressing or SOAP action http://docs.oasis-open.org/ws-sx/ws-trust/200512/RST/Validate • Request Type http://docs.oasis-open.org/ws-sx/ws-trust/200512/Validate

	• An additional *TRCParameter* in the namespace *http://ehdsi.eu/assertion/trc* for TRC and https://ehdsi.eu/assertion/nok for NOK with two children: *PurposeOfUse* and *PatientId* • The IdA as WS-Security supporting token (e.g., in the SOAP Header)
Output Message	A WS-Trust 1.3 *RequestSecurityTokenResponseCollection* containing the issued TRC assertion
Main Success Scenario	The TRC STS receives the *RequestSecurityToken* message. After validating the IdA, it issues a new TRC assertion with the desired PurposeOfUse and for the requested patient ID.

TRC-Assertions are validated by NCP-A internally, and it will not further specified by eHealth DSI.